

CleverHans Research: Gap Analysis vs. Hydra Framework

DECISION (2026-06-06): Reviewed and signed off. CleverHans is an **intel card only** — corroborating evidence that strengthens the convergence thesis across multiple existing Gen 1 capabilities (ao-1, ao-2, ao-5, cl-3, ev-1). **No gap status changes.** ao-1 is already EXISTS; ao-5 evasion is explicitly undemonstrated; no foundry loop demonstrated (sd-3). The Gen 2 analysis below is retained as research input for future Gen 2 whitepapers but is NOT actionable on the framework until those whitepapers are published. The 32-capability Gen 1 list is fixed.

Executive Summary

CleverHans demonstrates: Multi-target adaptive worm with recursive reasoning, field-to-foundry integration, and self-sustaining architecture.

What it provides: Corroborating evidence across 5+ Gen 1 capabilities — strengthens the thesis that the orchestration layer is closer than assessed. Does not move any gap status.

What it leaves red: All 4 remaining gaps (ao-5, c2-5, ip-1, sd-3) are untouched. Evasion explicitly undemonstrated, targeting indiscriminate, no foundry loop.

Framework action: Add intel-cleverhans-worm card to tracker. No `gaps.json` changes.

Part 1: CleverHans Research Overview

What It Demonstrates

AI-Driven Adaptive Computer Worm (Proof-of-Concept)

Technical Characteristics:

- └ Model: Open-weight LLM (single GPU)
- └ Network: Heterogeneous (Linux, Windows, IoT)

- └ Execution: Recursive reasoning per target
- └ Propagation: 5-day timeline to reach 50% of network
- └ Vulnerability targeting: Public CVEs + misconfigurations (no zero-days)
- └ Self-sustainability: Parasitic (uses victim compute resources)
- └ Integration: CVE incorporation within hours of disclosure
- └ Scope: Isolated virtual network (NOT field-deployed)

Key Findings:

1. ✓ Small models sufficient (don't need frontier models)
2. ✓ Vendor safety controls irrelevant (open-weight, local)
3. ✓ Economics of attack collapse (marginal cost → zero)
4. ✓ Economic barrier to attack eliminated
5. ✓ Reasonable detection window (5 days, but compressing with hardware)
6. ✓ Each instance differs (implicit polymorphism)

What It Explicitly Doesn't Demonstrate

NOT IN SCOPE (Intentionally Omitted):

- └ Concealment capabilities
- └ EDR evasion (adaptive, not static)
- └ Deception (no honeypot detection)
- └ Field deployment (lab only)
- └ Zero-day discovery (uses known CVEs)
- └ Log sanitization
- └ Advanced persistence mechanisms
- └ Real-time SOC hunting response
- └ Strategic targeting (targets all reachable, not selective)

BEHAVIORAL SIGNATURES LEFT INTACT (For Testing Purposes):

- └ Beacon callbacks on non-standard ports ← Detectable
- └ Automated SSH key injection ← Detectable
- └ Systematic credential reuse ← Behavioral signature
- └ No attempt to hide these signals

Part 2: Layer 1 Impact (Original 32 Capabilities)

Capabilities That Move (Status Change)

ao-1: Recursive Problem-Solving

Before: GAP (RED) - No evidence of AI autonomously reasoning about diverse targets - Theoretical capability only

After: PARTIAL (AMBER) - CleverHans demonstrates recursive reasoning loop - AI formulates target-specific attack strategies in real-time - Proof: "goal-directed reasoning that adapts to vulnerabilities of each target"

Evidence: - CleverHans directly quotes: "The worm replaces fixed exploitation code with goal-directed reasoning that adapts to the vulnerabilities of each target in real time." - Mechanism: Single-GPU LLM queried by lightweight agents for reasoning - Scope: Controlled environment, not field-deployed → PARTIAL, not EXISTS

What this means: - ✓ Orchestration layer can think - ✗ But only in controlled/homogeneous environments - ✗ Field-deployed heterogeneous SOC environments remain unproven

Tier implications: - Tier 1-2: "We knew this worked, now have lab proof" - Tier 3: "This is new research, need to test ourselves" - Tier 4-5: "Theoretical still, out of reach"

ao-5: Field-to-Foundry Integration / Adaptive Evasion

Before: GAP (RED) — Two separate gaps actually - No evidence of field intelligence flowing to foundry - No evidence of real-time evasion adaptation

After: PARTIAL (AMBER) — But only for one dimension - Field integration: **Demonstrated** — CVE incorporation within hours - Evasion adaptation: **NOT demonstrated** — No SOC hunting response

Field-to-Foundry (Demonstrated): - CleverHans: "capable of incorporating newly published vulnerabilities within hours of disclosure" - Mechanism: Worm reconnaissance feeds new CVEs → LLM reasons about exploitation → tool selection - Evidence: Real-time CVE discovery loop working - Status: **PARTIAL** ✓

Evasion Adaptation (NOT Demonstrated): - CleverHans: Signatures "intentionally omitted" — no active hiding - No detection of SOC hunting - No runtime adaptation to defensive pressure - Status: **Still GAP** ✗

Breakdown:

```
ao-5 Composite Gap:
├─ Field intelligence collection: EXISTS
├─ Real-time tool integration: PARTIAL ← CleverHans proves this
├─ Adaptive evasion vs hunting: GAP ← CleverHans explicitly omits this
└─ Overall: Upgrade ao-5 from GAP to PARTIAL
    (But with caveat: only field integration, not evasion)
```

ao-2: Real-Time Tool Selection

Before: PARTIAL (AMBER) - Multi-agent frameworks demonstrated (PentAGI, NodeZero) - But limited to controlled environments

After: PARTIAL ↑ (Upgraded within PARTIAL tier) - CleverHans strengthens evidence: "agentic framework for recursive reasoning, memory management, and tool use" - Demonstrates tool use against diverse targets - Tiered compute model (lightweight agents query GPU for reasoning)

Reinforcing Evidence: - Multi-agent architecture with different roles - Tool selection adapts per target - Not new capability, but stronger evidence - Status: Reinforcement of existing PARTIAL (no change)

Capabilities That Stay Unchanged

Layer 1 Capabilities NOT Advanced by CleverHans

STILL EXISTS:

- ✓ Autonomous vulnerability scanning (XBOW, Horizon3 precedent)
- ✓ Autonomous exploit execution (same)
- ✓ C2 via legitimate cloud services (GitHub API demonstrated in worm)
- ✓ Polymorphic code mutation (implicit in "each instance differs")
- ✓ Multi-mechanism persistence (not demonstrated, but not contradicted)
- ✓ Selective data identification (not in worm scope)
- ✓ Living off the land (likely used, not emphasized)

STILL PARTIAL:

- ✓ Zero-day weaponization (not tested with zero-days, only CVEs)
- ✓ Lateral movement (implied in propagation, not explicit)
- ✓ Privilege escalation (minimal, local execution)
- ✓ AI-driven lateral movement (propagation demonstrates it)
- ✓ Environment value assessment (worm targets indiscriminately)

STILL GAP:

- x Selective IP targeting (captures-the-flag objective)
 - x Legitimate user traffic mimicry (standard protocols only)
 - x Automated field-to-foundry feedback loop (no deployment mechanism shown)
 - x Adaptive evasion vs SOC hunting (intentionally undemonstrated)
-

The Three Red Gaps (Unchanged by CleverHans)

ao-3: Environment Value Assessment

Status: STILL GAP (RED)

Why CleverHans doesn't close it: - Worm targets all reachable hosts (no selective targeting) - No understanding of business value - No objective function beyond "propagate" - Quotes: "extend the attack surface to any networked device"

What would close it: - Autonomous assessment of: "Is this host valuable for IP theft?" - Understanding of: crown jewel locations, business criticality, IP concentration - Decision-making: "Exfil this database vs. ignore that file server"

CleverHans demonstrates: Indiscriminate propagation **CleverHans omits:** Discriminate targeting based on value

Timeline impact: No acceleration on this gap

c2-5: Legitimate User Traffic Mimicry

Status: STILL GAP (RED)

Why CleverHans doesn't close it: - Uses standard SSH, standard protocols - No baseline training on specific user - No behavioral mimicry (just legitimate-protocol reuse) - Detectable by network baseline analytics

What would close it: - Per-user behavioral baseline (collected over weeks) - C2 that mimics THIS USER'S traffic patterns - Timing, volume, endpoints all indistinguishable from baseline - Defeats UEBA/behavioral network detection

CleverHans demonstrates: Legitimate-protocol C2 (basic) **CleverHans omits:** User-specific behavioral mimicry

Timeline impact: No acceleration on this gap

sd-3: Automated Field-to-Foundry Feedback Loop

Status: STILL GAP (RED)

Why CleverHans doesn't close it: - Worm does NOT request custom exploits from foundry - Worm does NOT wait for new implants - Worm uses pre-built

arsenal (CVE database, not custom development) - No deployment mechanism shown for new implants mid-campaign

What would close it: - Field agent: "I found X vuln, need exploit for Y, build Z evasion" - Foundry: Autonomous response within hours with custom implant - Deployment: Field agent receives + deploys custom implant automatically - Integration: Foundry feeding field agent continuously

CleverHans demonstrates: CVE integration (static arsenal update)

CleverHans omits: Custom exploit generation and autonomous deployment

Timeline impact: No acceleration on this gap; Gap remains critical blocker

Part 3: Gen 2 Impact (Orchestration Capabilities)

Gen 2 Capabilities CleverHans Enables

G2-2.1: Sacrificial Implant Reconnaissance

Status: CleverHans moves from NEAR-EXISTS → PARTIAL

Why: - CleverHans worm IS a form of sacrificial probe (expected to be detected) - Demonstrates: "Deploy implant, measure response, learn SOC posture" - Field demonstration: 5-day propagation teaches about network topology - Multiple propagation attempts teach about detection mechanisms

Evidence in CleverHans: - "beacon callbacks on non-standard ports" ← Signals being left intentionally - Propagation itself is reconnaissance (tests what works on each host) - Timing data (5 days to 50%) teaches about detection windows

What's still missing: - Coordinated with primary campaign (worm is the primary, not sacrificial) - Feedback mechanism (results don't inform next phase) - SOC classification (doesn't measure Tier 1 vs Tier 5)

Timeline impact: +3 months (Gen 2-2.1 moves to PARTIAL)

G2-1.1: Multi-Implant Orchestration Foundation

Status: Strengthens foundation, but not fully demonstrated

Why: - CleverHans architecture uses tiered compute (lightweight agents + GPU nodes) - Each compromised GPU becomes attack infrastructure - Implicit multi-implant orchestration (different agents on different hosts)

Evidence in CleverHans: - "Each compromised machine becomes part of the worm's own infrastructure" - Tiered design: "lightweight agents on downstream devices querying GPU-equipped nodes" - Demonstrates: Infrastructure reuse for command routing

What's still missing: - Simultaneous campaigns with different C2 channels (only one worm) - Risk-tiered implants (Pawns/Knights/King strategy) - Different objectives per implant - Coordination logic (when to activate which implant)

Timeline impact: Modest (foundation exists, orchestration logic still needed)

G2-4.1: Strategic Retreat & Foundry Synchronization

Status: Conceptually demonstrated, but not operationally proven

Why: - CleverHans shows malware CAN retreat (intentional omission of capabilities) - Shows malware CAN operate minimally (focused only on propagation + reasoning) - Shows malware COULD receive updates (CVE integration mechanism)

Evidence in CleverHans: - Deliberately omits evasion, persistence, concealment - Implies: "This implementation is minimal, could be extended" - CVE incorporation shows: "Malware can receive intelligence, adapt arsenal"

What's explicitly missing: - Stage 1: Aggressive recon → Stage 2: Retreat - Actually going dormant - Waiting for foundry response - Accepting loss to gather intelligence

Timeline impact: +6 months (Gen 2-4.1 moves from RESEARCH toward NEAR-EXISTS)

Gen 2 Capabilities CleverHans Doesn't Enable

G2-2.2: EDR/AV-Specific Evasion Tuning

Status: RESEARCH (unchanged)

Why CleverHans doesn't help: - No EDR detection shown (worm doesn't attempt to evade anything) - No benchmarking against CrowdStrike vs Sentinel vs McAfee - No behavior modification based on identified EDR - Intentional omission: "detection or removal capabilities... deliberately omitted"

What's needed: - Identify which EDR is installed - Know specific behavioral signatures for that EDR - Modify implant behavior to avoid those signatures - Test against EDR-specific evasion

Timeline impact: None (no advancement from CleverHans)

G2-3.2: Autonomous Custom Exploit Generation

Status: RESEARCH (unchanged)

Why CleverHans doesn't help: - Worm uses CVE library (pre-existing knowledge) - No novel exploit development shown - No interaction with foundry for custom builds - No compilation of new implants mid-campaign

What's needed: - Foundry receives field intelligence - AI analyzes unpatched vulns in THIS org - AI generates custom exploit for THIS org's environment - AI deploys custom implant within hours

CleverHans shows: CVE integration (reading published intel) **CleverHans doesn't show:** Custom exploit generation (building novel exploits)

Timeline impact: None

G2-4.2: Dormancy Scheduling & Threat Hunt Evasion

Status: RESEARCH (unchanged)

Why CleverHans doesn't help: - Worm is not dormant (actively propagating for 5 days) - No SOC hunting detection - No response to active IR - Intentional: "does not attempt to cover its tracks"

What's needed: - Detect when SOC is actively hunting - Go completely silent (0 beacon activity) - Monitor when hunt ends (activity patterns return to baseline) - Resume only when safe

Timeline impact: None

Part 4: The Gaps That Remain (Still RED)

Critical Blocker: sd-3 (Automated Field-to-Foundry Feedback)

Status: STILL GAP (RED)

Why it matters: - Without sd-3, every campaign is generic - With sd-3, every campaign is custom-optimized for target

Impact on threat timeline:

WITHOUT sd-3 automation:

- Compromise org → Generic malware runs → SOC detects
- Timeline: Standard detection (48-72h)
- Dwell time: <1 week

WITH sd-3 automation:

- Compromise org → Field intelligence → Foundry generates custom → Custom malware runs
- Timeline: SOC detection delayed by custom evasion (+6-12h)
- Dwell time: 2-4 weeks

Why CleverHans doesn't close it: - Worm is self-contained (doesn't request custom implants) - No foundry interaction demonstrated - No custom deployment mechanism - CVE integration is static (published CVEs, not custom builds)

What would close it: - Field agent autonomous decision: "Time to retreat and report" - Foundry autonomous response: "Here are custom exploits for your environment" - Field agent autonomous deployment: "Received exploits, deploying lateral move"

Timeline to closure: 6-12 months (automation is the gap, not research)

Strategic Blocker: ao-3 (Environment Value Assessment)

Status: STILL GAP (RED)

Why it matters: - Determines WHERE to target (which orgs, which assets) - Determines WHEN to exfil (urgency signal) - Determines HOW LONG to dwell (time value of IP)

Impact on threat effectiveness: - Without ao-3: Treat all orgs the same (generic strategy) - With ao-3: Customize strategy per org (Tier 1 = 6-month dwell, Tier 5 = quick hit)

Why CleverHans doesn't close it: - Worm targets indiscriminately ("extend the attack surface to any networked device") - No understanding of which assets are valuable - No business intelligence assessment

What would close it: - Autonomous understanding of: "This org has crown-jewel IP worth \$10B, dwell 6 months" - Versus: "This org has no strategic value, quick ransomware hit" - Requires external intelligence integration

Timeline to closure: 12-24 months (research problem, requires ML+external intel)

Evasion Blocker: c2-5 (Legitimate User Traffic Mimicry)

Status: STILL GAP (RED)

Why it matters: - Defeats UEBA (User and Entity Behavior Analytics) - Makes C2 indistinguishable from normal user activity - Survives network-based detection

Impact on persistence: - Without c2-5: C2 beacons stand out in network baseline - With c2-5: C2 indistinguishable from THIS USER'S normal traffic

Why CleverHans doesn't close it: - Uses legitimate protocols (SSH) but not user-mimicking - No baseline training on specific user - No per-user behavioral modeling - Intentional omission: "It does not rely on concealment capabilities"

What would close it: - ML model of specific user's network behavior - C2 timing, volume, protocols match user's patterns exactly - Requires weeks of baseline observation per user

Timeline to closure: 12-18 months (ML infrastructure needed)

Part 5: The Four Red Gaps — CleverHans Impact Summary

Ranking by Difficulty (Hardest to Close First)

Gap	Status	Why Hard	CleverHans Impact	Timeline
ao-3	RED	Requires business intel	None	12-24mo
sd-3	RED	Automation of human process	None directly, but CVE integration shows framework	6-12mo
c2-5	RED	ML + baseline training	None	12-18mo
ao-5	AMBER	Moved by CleverHans (partially)	Partial closure (field intel works, evasion doesn't)	6mo improved

Part 6: Tier-by-Tier Implications

Tier 1 Actors (Nation-State)

Before CleverHans: - ✓ Could build adaptive worms (had capability) - ✓ Could integrate field intelligence (had capability) - ✗ Still didn't have automated sd-3 or ao-3

After CleverHans: - ✓ Lab proof validates Tier 1 assumptions - ✓ Acceleration: Timeline compressed by 3-6 months - → Move from "probable capability" to "confirmed capability" - → Likely already deploying similar systems (manually coordinated)

Change: +3-6 months on threat timeline

Tier 2 Actors (Criminal, Proxy State)

Before CleverHans: - ✗ Too expensive to build (research required) - ✗ No existing frameworks - ✗ Would take 18+ months

After CleverHans: - ✓ Proof-of-concept exists - ✓ Architecture documented - ✓ Open-weight models sufficient - → Timeline compressed: 18 months → 12 months - → Foundational skill available (some Tier 2 can copy)

Change: +6 months advancement (some Tier 2 can attempt)

Tier 3 Actors (Organized Crime, Regional)

Before CleverHans: - ✗ Beyond current capability - ✗ No framework to copy - ✗ Timeline: 24+ months

After CleverHans: - ✓ Proof-of-concept published - ✓ Framework is open-source-able - → Timeline compressed: 24+ months → 18-24 months - → Still difficult, but now copyable

Change: +3-6 months advancement (late followers only)

Tier 4-5 Actors (Script Kiddies, Low-Skill)

Before CleverHans: - ✗ Completely out of reach

After CleverHans: - ✗ Still out of reach (requires ML infrastructure) - ✓ But: Proof-of-concept is target for mimicry - → Timeline: Still 24+ months

Change: Minimal

Part 7: What CleverHans Actually Changes in the Framework

Layer 1 Changes

BEFORE CleverHans (May 2026):

- └─ ao-1: GAP
- └─ ao-5: GAP
- └─ All others: Status unchanged

AFTER CleverHans (June 2026):

- └─ ao-1: PARTIAL ← Demonstration of recursive reasoning
- └─ ao-5: PARTIAL ← Demonstration of field intelligence integration

- | (but NOT adaptive evasion vs hunting)
- └ All others: Status unchanged

Net change: 2 RED gaps moved to AMBER, 1 additional AMBER (ao-5 has two parts)

Gen 2 Changes

BEFORE CleverHans (May 2026):

- └ G2-2.1 (Sacrificial probes): NEAR-EXISTS
- └ G2-1.1 (Portfolio orchestration): RESEARCH
- └ G2-4.1 (Strategic retreat): RESEARCH
- └ All others: RESEARCH

AFTER CleverHans (June 2026):

- └ G2-2.1 (Sacrificial probes): PARTIAL ← Worm demonstrates probe concept
- └ G2-1.1 (Portfolio orchestration): Strengthened foundation (tiered compute)
- └ G2-4.1 (Strategic retreat): Conceptually strengthened (retreat possible)
- └ All others: RESEARCH (unchanged)

Net change: 1-2 Gen 2 capabilities accelerated by 3-6 months

Threat Timeline Compression

BEFORE CleverHans:

- Tier 1-2: "We think this works, proving it soon"
- Timeline to full Hydra model: 18-24 months
- Confidence: 70%

AFTER CleverHans:

- Tier 1-2: "Lab proof confirms assumptions, deploying now"
- Timeline to full Hydra model: 12-18 months
- Confidence: 85%

Acceleration: 6-12 months forward for Tier 1-2 actors

Part 8: The Remaining Research Gaps

What CleverHans Does NOT Solve

Three hard gaps remain RED:

ao-3 (Environment Value Assessment):

- └ Requires: Understanding of business value, competitive intel, IP assessment
- └ Not in CleverHans scope: Indiscriminate targeting only
- └ Timeline: 12-24 months (research gap)
- └ Impact: Limits targeting precision, not persistence

c2-5 (Legitimate User Mimicry):

- └ Requires: Per-user behavioral baseline (weeks of observation)
- └ Not in CleverHans scope: Standard protocols, no user-specific modeling
- └ Timeline: 12-18 months (ML infrastructure gap)
- └ Impact: C2 remains detectable via UEBA/behavioral analytics

sd-3 (Automated Field-to-Foundry):

- └ Requires: Fully autonomous foundry that receives intelligence + builds exploits
- └ Partially shown in CleverHans: CVE integration works, but it's static
- └ Missing: Custom exploit generation, autonomous deployment
- └ Timeline: 6-12 months (automation gap, not research gap)
- └ Impact: CRITICAL – enables everything else

Part 9: CleverHans in the Sankey Model

How CleverHans Changes Gen 2 Probability Flows

BEFORE (May 2026):

Layer 1: ao-1 GAP → G2-2.1 Sacrificial Probes [Probability: 30% at 12mo]
 ao-5 GAP → G2-3.2 Custom Exploit Gen [Probability: 20% at 18mo]

AFTER (June 2026):

Layer 1: ao-1 PARTIAL → G2-2.1 Sacrificial Probes [Probability: 60% at 6mo] ↑↑
 ao-5 PARTIAL → G2-3.2 Custom Exploit Gen [Probability: 50% at 12mo] ↑↑

Visual change in Sankey: - Flows get thicker (higher probability) - Timeline arrows shift left (sooner realization) - Colors shift from RED (24mo) to YELLOW (12mo) to GREEN (6mo)

Part 10: Critical Insight — What CleverHans Proves vs. Doesn't Prove

What It Proves (With High Confidence)

- ✓ Small open-weight models are sufficient
- ✓ Recursive reasoning per-target works in practice
- ✓ Field intelligence integration is possible
- ✓ Self-sustaining propagation is feasible
- ✓ CVE discovery → integration → deployment is rapid
- ✓ No vendor safety controls needed (open-weight)
- ✓ Detection window is measurable (5 days, but compressing)
- ✓ Economics collapse (marginal cost → zero)

What It Doesn't Prove (Major Gaps)

- x Automated foundry feedback (sd-3) – CVE integration ≠ custom exploit generation
- x Adaptive evasion vs hunting – Intentionally undemonstrated
- x Environment value assessment – Indiscriminate targeting shown
- x User traffic mimicry – Standard protocols only
- x Long-term dormancy – Continuous active propagation shown
- x Strategic retreat coordination – No multi-stage orchestration
- x Field deployment – Lab only, not operational
- x Tier-dependent tactics – Single strategy for all targets

Summary Table: CleverHans vs. Hydra Framework

Dimension	Hydra Layer 1 Impact	Hydra Gen 2 Impact	Threat Timeline	Confidence
ao-1: Recursive reasoning	GAP → PARTIAL	Enables G2-1.1 foundation	+3mo	High
ao-5: Field intelligence	GAP → PARTIAL	Enables G2-3.1, G2-4.1	+3mo	High
ao-3: Value assessment	No impact	No impact	No change	Same
c2-5: User mimicry	No impact	No impact	No change	Same
sd-3: Foundry automation	No impact (CVE≠custom)	Partial enable G2-3.2	+3mo potential	Medium

Dimension	Hydra Layer 1 Impact	Hydra Gen 2 Impact	Threat Timeline	Confidence
Overall threat vector	2 gaps close	2-3 capabilities accelerate	+6-12mo	High
Tier 1-2 timeline	Compressed to 12-18mo	Portfolio strategy viable	-6 months	High

Conclusion: What Changes, What Doesn't

CleverHans proves the Hydra is achievable sooner than expected.

It closes 2 Layer 1 gaps (ao-1, ao-5 partially), accelerates 2-3 Gen 2 capabilities, and compresses Tier 1-2 threat timeline by 6-12 months.

But it leaves the three hardest gaps untouched: - ao-3 (value assessment) — Still requires business intelligence - c2-5 (user mimicry) — Still requires ML infrastructure - sd-3 (foundry automation) — Still requires autonomous exploit generation

The 12-18 month window is now the critical threat timeline. By June 2027, multi-stage portfolio attacks with foundry feedback should be operational for Tier 1 actors.